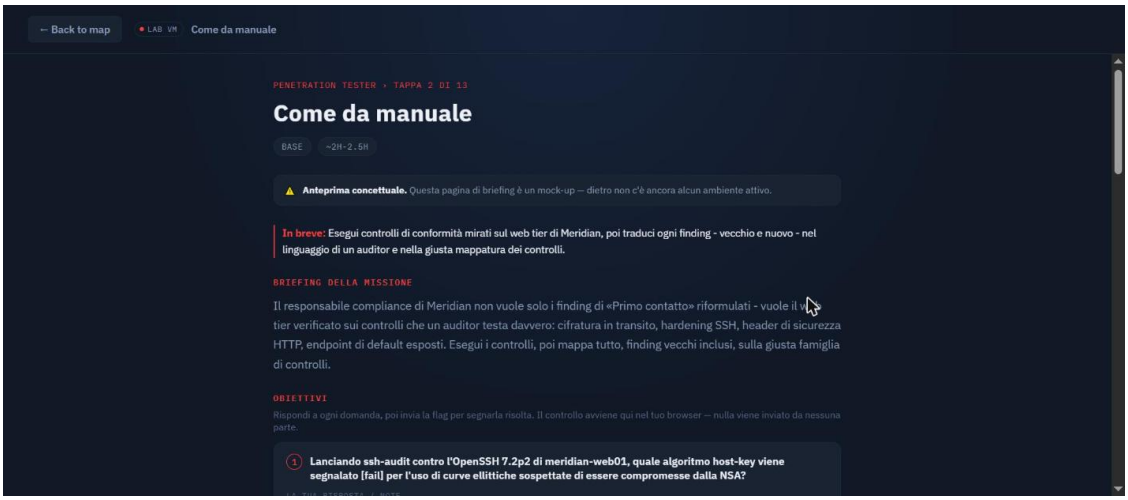
Come da manuale — Explanation

Ruolo: Penetration Tester — tier **va** (Vulnerability Analyst, CREST CPSA)
Lab id: by-the-book · **Difficoltà**: Base · **Durata stimata**: ~2h-2.5h
Lab component: lxr:net-perimeter (condiviso con "Primo contatto")

---

1. Schermata del lab (Avvia lab)



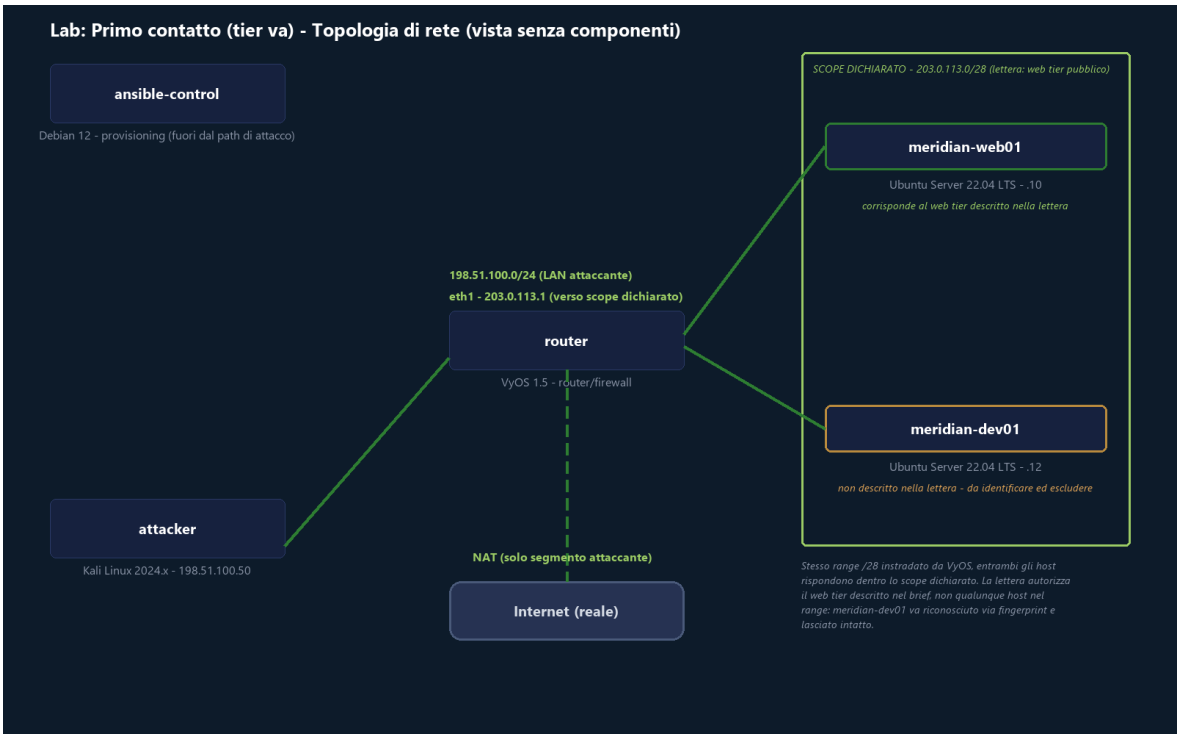
Screenshot reale della pagina di briefing così come appare oggi in piattaforma (versione HTB-restyled). La pagina è un mock-up concettuale: non c'è un ambiente live dietro. Come per Primo contatto, nessun dato tecnico è già pronto da leggere nel testo: ogni finding deve emergere da un comando eseguito davvero sul target (vedi sezione 7).

2. Infrastruttura

Questo lab riusa esattamente l'ambiente di "Primo contatto" (stesso `lxr:net-perimeter`): stessi host, stessa rete, stesso scope dichiarato (203.0.113.0/28). Non viene provisionata alcuna macchina nuova. L'unica differenza di configurazione riguarda meridian-web01: `ConfigureApache2` ora abilita anche `mod_status` (endpoint `/server-status`), lasciato senza restrizioni di accesso — il dettaglio che rende reale l'obiettivo 4 di content discovery (sezione 4). Tutto il resto — OS, servizi, interfacce, confine di scope — resta identico a quanto già documentato in `docs/labs/first-contact/`.



Stessa topologia di Primo contatto — diagramma sorgente editabile in `docs/labs/first-contact/first-contact-topology.drawio`. Non duplicato in questa cartella perché nulla a livello di rete o host cambia per questo lab.



Vista equivalente senza componenti, stesso file sorgente di Primo contatto (`first-contact-topology-network-only.drawio`).

3. Perché queste scelte

Storytelling

• **Stesso cliente, richiesta diversa**: Meridian Outfitters e il suo compliance officer mantengono la continuità narrativa con Primo contatto, ma la domanda si sposta da "cosa è esposto" a "supereremmo un audit con quello che abbiamo trovato".

• **Non più un esercizio di sola lettura di standard**: ogni finding nuovo nasce da un comando reale lanciato contro il target, non da una domanda di cultura generale scollegata dal lab — coerente con l'obiettivo di farlo sembrare lavoro da analista, non un quiz.

• **La flag di sintesi finale (#5)** tiene viva l'identità originale del lab — "tradurre in linguaggio da auditor" — perché obbliga a classificare tutti e sei i finding raccolti (i 2 di Primo contatto più i 4 di oggi), non solo quelli trovati in questa sessione.

• **Nessuna exploitation**: il lab resta di tier va (CREST CPSA, "Practitioner", supervisionato) — anche gli strumenti nuovi (ssh-audit, nikto, gobuster) sono strumenti di auditing/enumerazione passiva, non di attacco.

Infrastrutturali

• **Riuso totale dell'infrastruttura di Primo contatto**: nessuna nuova VM, nessun nuovo segmento di rete — zero costo aggiuntivo di provisioning, coerente con un lab "da scrivania più verifica mirata" più che un nuovo assessment completo da zero.

• **Un'unica aggiunta, deliberatamente minima**: `mod_status` abilitato su meridian-web01 senza restrizioni è un errore di configurazione comune e realistico (modulo lasciato attivo dopo il setup iniziale, mai rimosso), non un artefatto costruito apposta per far quadrare il lab.

• **Stessi binari di Primo contatto** (OpenSSH 7.2p2, Apache 2.4.18, già fissati per le due CVE): i nuovi finding (algoritmi deboli, header mancanti) emergono dal fatto che quei servizi non sono mai stati sottoposti a un hardening successivo all'installazione — stessa narrativa di fondo, letta da un'angolazione diversa (configurazione, non patch mancanti).

• **Nessun nuovo tool o configurazione su router o ansible-control**: solo l'attaccante riceve tre pacchetti aggiuntivi (ssh-audit, nikto, gobuster), per restare minimale.

4. Obiettivi

#	Domanda (flag)	Risposta
1	Lanciando ssh-audit contro l'OpenSSH 7.2p2 di meridian-web01, quale algoritmo host-key viene segnalato [fail] per l'uso di curve ellittiche sospettate di essere compromesse dalla NSA?	FLAG{ECDSA-SHA2-NISTP256}
2	Scansionando le porte web di meridian-web01 trovi la 80 aperta e la 443 chiusa. Per un retailer in ambito PCI DSS, quale controllo di sicurezza risulta quindi completamente assente sul sito verso i clienti?	FLAG{NO-TLS}
3	Controllando gli header HTTP di risposta di meridian-web01, qual è l'header mancante che normalmente impedisce alla pagina di essere incorporata in un frame di un altro sito (protezione da clickjacking)?	FLAG{X-FRAME-OPTIONS}
4	Eseguendo una content discovery su meridian-web01, trovi un endpoint diagnostico di default di Apache mai disabilitato dopo l'installazione, che espone dati live su connessioni e worker. Qual è il suo path?	FLAG{SERVER-STATUS}
5	Hai ora sei finding totali tra Primo Contatto e questo lab. Cinque sono difetti di patch o configurazione che rientrano nella famiglia System and Information Integrity (SI) di NIST SP 800-53 - ma uno riguarda la protezione dei dati in transito e appartiene a una famiglia completamente diversa. Quale?	FLAG{SC}

Mappatura ECSF: Task T3 "Test systems and operations compliance with regulatory standards", T8 "Deploy penetration testing tools and test programs" · Skill S8 "Use penetration testing tools effectively", S9 "Conduct technical analysis and reporting" · Knowledge K8 "Penetration testing tools", K11 "Cybersecurity recommendations and best practices".

Perché questi obiettivi

• **Flag 1 (ssh-audit)**: invece di una domanda di cultura generale su un framework, il finding nasce da un comando reale lanciato contro OpenSSH 7.2p2 — lo studente impara un tool nuovo (configuration/hardening auditing), distinto dal semplice version fingerprinting già fatto in Primo contatto.

• **Flag 2 (niente TLS)**: collega un fatto tecnico verificabile (porta 443 chiusa) a un requisito di compliance concreto (PCI DSS, cifratura dei dati in transito) — rilevante perché Meridian è un e-commerce.

• **Flag 3 (header mancante)**: introduce un angolo di auditing diverso — configurazione lato applicativo, non versione del servizio — con uno strumento nuovo (nikto).

• **Flag 4 (content discovery)**: prima content discovery del percorso (gobuster); il finding (mod_status esposto) è un errore di configurazione reale, non un CVE, a differenza di tutto quanto visto finora.

• **Flag 5 (sintesi)**: obbliga a riprendere tutti e sei i finding raccolti finora (anche quelli di Primo contatto) e classificarli per famiglia di controllo — è la flag che restituisce al lab la sua identità originale di "traduzione in linguaggio da auditor", e richiede di accorgersi che la cifratura in transito non è un problema di patch (famiglia SI) ma di comunicazioni protette (famiglia SC) — un errore di classificazione comune per un analista junior.

• Nessuna flag richiede exploitation: tutti gli strumenti usati sono di auditing/enumerazione passiva, coerenti con il tier va.

• Difficoltà "Base" ma durata salita a ~2h-2.5h rispetto alla versione precedente del lab: cinque obiettivi pratici più la sintesi finale pesano più delle tre domande originali, pur restando alla portata di un primo/secondo lab del percorso.

5. Tool, OS e configurazioni

Componente	OS / Tecnologia	Install	Configure

meridian-web01 (target, in scope)	Ubuntu Server 22.04 LTS	Apache2, OpenSSH Server	ConfigureLegacyPackageSource, ConfigureApache2 (+ mod_status), ConfigureOpenSSHServer
attacker	Kali Linux 2024.x	ssh-audit, nikto, gobuster	ConfigureDirbWordlists (per gobuster)

Perché proprio questi tool/OS/configurazioni

• **ssh-audit**: pacchetto reale disponibile via apt su Kali (stesso repository Debian su cui Kali si basa); nessuna configurazione necessaria oltre l'installazione.

• **nikto**: scanner di configurazione web storico, incluso in Kali, adatto a rilevare header di sicurezza mancanti senza bisogno di credenziali né di alcuna exploitation.

• **gobuster**, con la wordlist di dirb già presente su Kali (`/usr/share/wordlists/dirb/common.txt`): content discovery minimale, stessa filosofia "tool reali, non inventati" di tutto il resto del laboratorio.

• **ConfigureApache2 aggiornato** per abilitare mod_status su meridian-web01, lasciandolo senza restrizioni di accesso: l'unica modifica infrastrutturale rispetto a Primo contatto.

• **Nessun nuovo tool o configurazione su router o ansible-control**: il lab resta deliberatamente minimale nelle modifiche infrastrutturali.

6. Playbook section

Da completare. Qui andranno elencati i playbook Ansible effettivi (uno per componente o un playbook unico con ruoli separati), con il percorso del repository e la mappatura ruolo → task Ansible.

7. Lab solution

1. Verifica dello scope

Stesso scope autorizzato di Primo contatto (203.0.113.0/28), già verificato in quel lab. Qui non serve rifare la discovery: si riparte direttamente dall'host già identificato come target (meridian-web01, 203.0.113.10) tramite il fingerprint fatto in quella sessione.

2. Flag 1 — audit hardening SSH

```
ssh-audit 203.0.113.10
```

Tra gli algoritmi host-key segnalati `[fail]`, `ecdsa-sha2-nistp256` compare con la nota "using elliptic curves that are suspected as being backdoored by the U.S. National Security Agency" → **FLAG{ECDSA-SHA2-NISTP256}**.

3. Flag 2 — cifratura in transito

```
nmap -p 443 203.0.113.10
curl -I http://203.0.113.10/
```

Risultato: 443/tcp `closed`, nessun redirect verso HTTPS nella risposta sulla porta 80 — il sito gira interamente in chiaro. Per un retailer in ambito PCI DSS è un finding serio, non cosmetico → **FLAG{NO-TLS}**.

4. Flag 3 — audit header di sicurezza

```
nikto -h 203.0.113.10
```

Tra gli header mancanti segnalati, manca `X-Frame-Options`: nessuna protezione da clickjacking → **FLAG{X-FRAME-OPTIONS}**.

5. Flag 4 — content discovery

```
gobuster dir -u http://203.0.113.10 -w /usr/share/wordlists/dirb/common.txt
```

Tra i path trovati, `/server-status` risponde 200 ed espone connessioni e worker live di Apache — un endpoint diagnostico mai disabilitato dopo l'installazione → **FLAG{SERVER-STATUS}**.

6. Flag 5 — sintesi finale

Con tutti e sei i finding in mano (le 2 CVE di Primo contatto, l'algoritmo SSH debole e l'endpoint di default esposto da oggi) si classificano per famiglia di controllo NIST SP 800-53: sono tutti difetti di patch o configurazione → famiglia SI (System and Information Integrity). L'assenza di TLS, invece, riguarda la protezione dei dati in transito — famiglia SC (System and Communications Protection), non SI → **FLAG{SC}**.

7. Report finale

Tabella finding → famiglia di controllo → severità → raccomandazione, pronta per il compliance officer: le due CVE, l'algoritmo SSH debole e l'endpoint di default esposto restano priorità di patching/hardening sotto SI; l'assenza di TLS (SC) è l'unica voce fuori da quella famiglia; l'header mancante resta un finding applicativo a sé da segnalare, senza forzarne la famiglia NIST senza prima verificarla con il compliance officer.